

Compliance Frame Cards — SOC 2 / Privacy / Industry

Day 2 · Activity 3 handout. Three frames come up constantly, even at junior-TPM scope. A TPM doesn't write the compliance program — a TPM **flags which frame applies** and **drives the conversation** with the responsible team.

Card 1 — SOC 2 Type II

What it covers: Operational controls across five trust criteria — security, availability, confidentiality, processing integrity, and privacy.

Where it shows up: Most B2B SaaS sales requirements. Enterprise buyers ask for the report during procurement.

The TPM question: Are we handling customer data, audit-relevant actions, or availability commitments? *(For most B2B features: yes.)*

Common control this pulls in: User-action audit trail with a stated retention window (e.g., CC7.2 — 24-month retention).

☐ Applies to our feature? Y / N

- **Specific control our feature must respect:** _____

Card 2 — Privacy (GDPR / CCPA / state-level US privacy)

What it covers: Personal-data handling — collection, consent, access, and deletion rights.

Where it shows up: Anywhere you collect or process personal data of regulated residents (EU, California, other states).

The TPM question: Does this touch personal data of EU / California / other regulated residents? Which regime?

Common control this pulls in: Lawful basis for processing, data-subject deletion path, PII inventory (e.g., dispatcher name + employee ID → CCPA applies).

☐ Applies to our feature? Y / N

- **Regime(s):** _____
- **Specific control our feature must respect:** _____

Card 3 — Industry-specific

What it covers: Regime tied to the customer's industry or data type — HIPAA (health), PCI-DSS (payments), FERPA (education), SOX (public companies).

Where it shows up: When the customer is in that industry, or the data type pulls a regime in.

The TPM question: Is the customer in a regulated industry? Does the data type pull a regime in on its own?

Common control this pulls in: Depends on the regime — cardholder-data scoping (PCI-DSS), PHI handling (HIPAA), etc.

☐ Applies to our feature? Y / N

- **Regime(s):** _____
 - **Specific control our feature must respect:** _____
-

Frame check summary

For each "yes," list the **specific control** the framework requires that this feature must respect. Reference example (FieldPulse reconcile):

- SOC 2: User-action audit trail required (CC7.2). 24-month retention.
- Privacy: Dispatcher PII (name, employee ID) processed. CCPA applies.
- Industry-specific: None directly; some shops are CCPA-equivalent state coverage.

"No compliance applies" is almost never true. Default to SOC 2 for B2B SaaS unless you can show why not.